INFORME TÉCNICO DE LABORATORIO SOC

Fundamentos del Análisis de Phishing e Inspección Forense de Correos

Autor: Sebastián Navarro Maldonado **Proyecto:** Portafolio SOC Level 1 **Entorno:** Linux Sandbox / VM **Fecha:** Julio de 2026

1. RESUMEN EJECUTIVO

El presente documento consolida la metodología defensiva, las herramientas de consola y el análisis forense aplicado para la investigación de amenazas basadas en correo electrónico (*email threats*). El objetivo principal de este proyecto consistió en analizar archivos de correo sin procesar (`.eml` / `.txt`), identificar vectores de ingeniería social, extraer artefactos maliciosos en código Base64 mediante comandos del sistema operativo Linux y aplicar técnicas de neutralización de indicadores de compromiso (*defanging*).

2. MARCO TEÓRICO Y CLASIFICACIÓN DE AMENAZAS

Dentro del monitoreo en un Centro de Operaciones de Seguridad (*Security Operations Center* - SOC), los vectores de correo electrónico representan la superficie de ataque más explotada por actores de amenaza.

2.1 Tipología de Correos Maliciosos

- **Spam y Malspam:** Envíos masivos no solicitados. Cuando el mensaje transporta carga útil maliciosa (*payload*), se clasifica como *malspam*.
- **Suplantación de Identidad (*Phishing*):** Envíos genéricos que simulan provenir de entidades legítimas para capturar credenciales o datos financieros.
- **Ataque Dirigido (*Spear Phishing*):** Vectores personalizados dirigidos a individuos o departamentos específicos tras una fase previa de reconocimiento (*reconnaissance*).
- **Ataque a Ejecutivos (*Whaling*):** Subtipo de *spear phishing* orientado a la alta dirección (CEO, CFO) para la autorización de transferencias o acceso a información confidencial.
- **Fraude de Correo Corporativo (*Business Email Compromise* - BEC):** Compromiso o suplantación de cuentas corporativas legítimas para engañar a empleados o proveedores y cometer fraude financiero.
- **Ingeniería Social por SMS (*Smishing*) y Voz (*Vishing*):** Ataques que desplazan el vector de engaño hacia mensajería móvil o llamadas telefónicas.

2.2 Protocolos e Infraestructura de Correo

- **SMTP (*Simple Mail Transfer Protocol*):** Protocolo encargado del envío e interconexión de servidores de correo.
- **POP3 (*Post Office Protocol 3*):** Descarga el mensaje al dispositivo local (habitualmente eliminándolo del servidor).
- **IMAP (*Internet Message Access Protocol*):** Mantiene los correos sincronizados directamente en el servidor central.

3. METODOLOGÍA DE ANÁLISIS Y DETECCIÓN EN VIVO

El análisis forense de un archivo de correo se dividió en tres capas fundamentales:

> **Flujo de Inspección del Archivo (.eml / .txt)**
> 1. **Encabezados (Headers):** Servidores recibidos, verificación SPF/DKIM y trazabilidad de IP de origen.
> 2. **Cuerpo (HTML):** Detección de enlaces ocultos, imágenes remotas e inconsistencias de marcas.
> 3. **Adjuntos (Attachments):** Identificación de bloques Base64, decodificación y extracción de IoCs.

A. Inspección de Encabezados (*Email Headers*)

- **Identificación del Remitente Real:** Comparación directa entre la cabecera visible (`From:`) y la ruta de retorno real (`Return-Path:`).
- **Servidores de Autenticación:** Verificación del encabezado `Authentication-Results:` para validar los resultados de **SPF** (*Sender Policy Framework*), **DKIM** (*DomainKeys Identified Mail*) y **DMARC**.
- **Trazabilidad de IP de Origen:** Extracción de la dirección de origen mediante la etiqueta `X-Originating-IP:` .

B. Análisis de Código HTML

Inspección de la estructura interna para detectar discrepancias entre el texto visible del hipervínculo y la URL real de destino en la etiqueta `<a href="...">`, previniendo la suplantación de marcas legítimas (*Brand Impersonation*).

C. Reconstrucción de Artefactos Codificados

Los archivos adjuntos se transmiten mediante la extensión MIME (*Multipurpose Internet Mail Extensions*) utilizando codificación Base64. Se analizaron las propiedades `Content-Type` , `Content-Disposition` y `Content-Transfer-Encoding` .

4. PROCEDIMIENTO TÉCNICO Y COMANDOS DE CONSOLA (BASH)

Para evitar latencias e inconvenientes gráficos en el entorno virtual, la investigación se ejecutó íntegramente mediante la línea de comandos de Linux (*Linux Terminal*).

4.1 Búsqueda e Extracción de Metadatos

Para filtrar los campos de remitente y asunto sin cargar el archivo completo:

```
grep -E -i "^From:|^Subject:" "/home/ubuntu/Desktop/Email Samples/email3.eml"
```

Para identificar la dirección IP origen del ataque:

```
grep -i "X-Originating-IP" "/home/ubuntu/Desktop/Email Samples/email3.eml"
```

Para determinar el servidor de correo que procesó las reglas de autenticación:

```
grep -i "Authentication-Results" "/home/ubuntu/Desktop/Email Samples/email3.eml"
```

4.2 Decodificación de Archivos Adjuntos (Base64 a PDF)

Para procesar un archivo con datos adjuntos omitiendo las líneas iniciales de encabezado que corrompen la decodificación, se utilizó la canalización de comandos (*pipeline*):

```
tail -n +5 "/home/ubuntu/Desktop/Email Samples/email2.txt" | base64 -d -i > ~/Desktop/flag.pdf
```

Desglose del comando:

- `tail -n +5`: Omite las primeras 4 líneas de encabezados y lee desde la línea 5 (inicio de la cadena Base64).
- `|` (Pipe): Envía el flujo de datos directamente al siguiente comando.
- `base64 -d -i`: Decodifica (`-d`) e ignora caracteres basura o saltos de línea no estándar (`-i`).
- `> ~/Desktop/flag.pdf`: Redirecciona la salida binaria para reconstruir el archivo PDF en el Escritorio.

Para abrir el documento reconstruido directamente desde la terminal:

```
xdg-open ~/Desktop/flag.pdf
```

5. SANITIZACIÓN Y NEUTRALIZACIÓN DE ARTEFACTOS (DEFANGING)

Antes de registrar o compartir los Indicadores de Compromiso (*Indicators of Compromise* - IoCs) en reportes de incidentes, es mandatorio neutralizar las direcciones para evitar ejecuciones o clics accidentales.

Tipo de Artefacto	Valor Original (Activo)	Valor Neutralizado (*Defanged*)
Dirección IP	103.234.236.83	`103[.]234[.]236[.]83`
Dominio	suspiciousdomain.com	`suspiciousdomain[.]com`
URL Web	http://t.teckbe.com/p/?j3	`hxxp[://]t[.]teckbe[.]com/p/?j3`
Correo Electrónico	support@teckbe.com	`support[@]teckbe[.]com`

6. CONCLUSIÓN

El análisis de correos electrónicos sospechosos requiere un enfoque metódico que va más allá de la simple inspección visual. La capacidad de descomponer la estructura MIME, analizar encabezados SMTP y decodificar artefactos binarios directamente desde la línea de comandos representa una habilidad crítica para acortar los tiempos de respuesta (*Mean Time to Detect / Respond* - MTTD/MTTR) en un SOC.

La utilización de herramientas de consola en entornos Linux demuestra ser el camino más eficiente y robusto para evadir las limitaciones o trampas de renderizado que los atacantes suelen preparar dentro del código HTML o en los clientes de correo tradicionales.

7. PERCEPCIONES Y LECCIONES APRENDIDAS

- **Eficacia de la Consola sobre la GUI:** La manipulación de artefactos mediante herramientas CLI (*Command Line Interface*) previene la interacción accidental con enlaces maliciosos y soluciona problemas de rendimiento o bloqueos del sistema causados por la interfaz gráfica.
- **Importancia de la Neutralización de IoCs:** Documentar direcciones IP o enlaces en formato activo representa un riesgo operacional dentro de los sistemas de ticketing. La neutralización (*defanging*) debe ser una práctica estandarizada desde la primera fase de investigación.
- **Evolución de la Ingeniería Social:** Los atacantes combinan suplantación de identidad en cabeceras (*spoofing*) con archivos adjuntos legítimos en apariencia para eludir los controles perimetrales. El análisis de firmas y encabezados SPF/DKIM sigue siendo la primera línea de defensa técnica.